Clase 071 — Análisis de vulnerabilidades con Nessus y OpenVAS

> Parte: **3 — Hacking ético y pentesting: metodología** · Fuente: *PTES (Penetration Testing Execution Standard) - fase de Vulnerability Analysis; NIST SP 800-115* ⏱️ Duración estimada: **120 min** · Nivel: **Intermedio**

🎯 Objetivo

El alumno aprenderá a operar dos escáneres de vulnerabilidades de clase empresarial —Nessus (edición Essentials) y OpenVAS/Greenbone Vulnerability Management (GVM)— para descubrir, clasificar y priorizar debilidades en sistemas de un laboratorio controlado. Al terminar la clase, el alumno entenderá cómo se construye una política de escaneo, cómo se interpreta un hallazgo con su puntaje CVSS y por qué el analista humano sigue siendo indispensable para separar el ruido de los riesgos reales.

📚 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. Instalar y configurar Nessus Essentials y OpenVAS/GVM en un entorno de laboratorio aislado.
2. Crear políticas de escaneo ajustadas al alcance (scope) definido en un contrato de pentesting.
3. Ejecutar escaneos de descubrimiento y de vulnerabilidades autenticados y no autenticados.
4. Interpretar el puntaje CVSS v3.1 (base, temporal, ambiental) de un hallazgo.
5. Correlacionar un hallazgo del escáner con su entrada correspondiente en CVE/NVD.
6. Distinguir falsos positivos de riesgos reales y priorizar la remediación según impacto de negocio.

🗺️ Temas

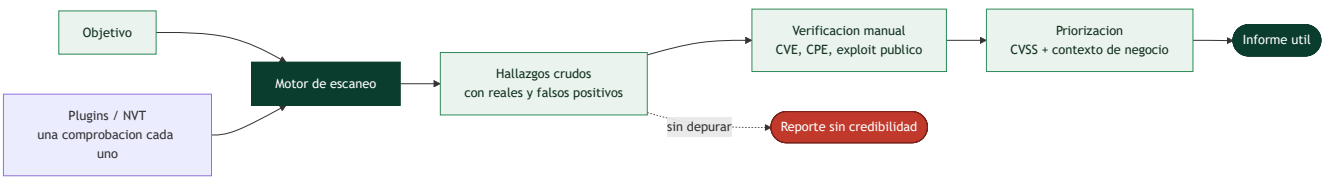
#	Tema	Por qué importa
1	Arquitectura de un escáner de vulnerabilidades	Entender motor de escaneo, plugins/NVTs y base de firmas explica sus límites
2	Nessus Essentials: instalación y activation code	Es el estándar de facto en la industria; Essentials permite practicar sin costo hasta 16 IPs
3	OpenVAS/Greenbone (GVM): arquitectura de contenedores	Alternativa open source auditable, usada en muchos SOC y auditorías gubernamentales
4	Políticas de escaneo y templates	Un escaneo mal configurado puede tumbar servicios frágiles o generar falsos negativos
5	Escaneo autenticado vs no autenticado	El autenticado revela vulnerabilidades locales (parches faltantes); el no autenticado simula un atacante externo
6	CVSS v3.1: vectores base, temporal y ambiental	Es el lenguaje universal para priorizar remediación entre equipos
7	Correlación con CVE, NVD y CPE	Permite verificar manualmente un hallazgo y buscar exploits públicos asociados
8	Gestión de falsos positivos y priorización	Un reporte sin depurar pierde credibilidad frente al cliente o al equipo de TI

🧠 Explicación en profundidad

Un escáner amplía, no profundiza

Un escáner de vulnerabilidades (Nessus, OpenVAS/Greenbone) automatiza la comparación entre lo que encuentra en un objetivo y una **base de firmas** de problemas conocidos. Su valor es la **amplitud**: revisa cientos de hosts contra decenas de miles de comprobaciones en el tiempo que un humano tardaría en mirar uno. Su límite es que **no piensa**: no encadena hallazgos, no entiende el contexto de negocio y, sobre todo, **no confirma explotabilidad**. Por eso el escaneo no sustituye al pentest; lo alimenta. Interpretar bien su salida —separar lo real de lo ruidoso— es la destreza que esta clase enseña.

Entender su arquitectura explica sus fallos. Un escáner tiene un **motor** que orquesta las pruebas, un conjunto de **plugins** o **NVT** (uno por comprobación, actualizados a diario) y una base de firmas. Cuando la firma de un plugin se limita a mirar el banner de versión, el escáner reporta como vulnerable un servicio que quizá esté parcheado por *backport* (el problema de la Clase 031): de ahí nacen la mayoría de los falsos positivos.



Autenticado frente a no autenticado: dos preguntas distintas

La decisión de configuración que más cambia el resultado es si el escaneo se hace **con o sin credenciales**. Un escaneo **no autenticado** ve el objetivo como lo vería un atacante externo: solo lo expuesto en red. Un escaneo **autenticado** entra con credenciales y audita desde dentro —parches faltantes, software vulnerable instalado, configuraciones inseguras—, con muchísima más profundidad y muchísimos menos falsos positivos, porque comprueba la versión real del paquete en lugar de adivinarla por el banner. Los dos responden preguntas legítimas pero diferentes: "¿qué ve un externo?" frente a "¿qué vulnerabilidades hay realmente en estos equipos?". En una auditoría de cumplimiento suele pedirse el autenticado; en una simulación de atacante, el no autenticado.

Y una advertencia operativa que se repite: un escáner mal configurado **puede tumbar servicios frágiles**. Las comprobaciones intrusivas, o simplemente el volumen de tráfico, cuelgan impresoras, dispositivos IoT y sistemas SCADA. Las plantillas de política existen justamente para acotar esto —hay perfiles "seguros" que excluyen las pruebas peligrosas— y usarlas es parte de operar dentro de las RoE de la Clase 067.

CVSS: el lenguaje común para priorizar, con sus trampas

CVSS (v3.1) puntúa la severidad de una vulnerabilidad de 0 a 10 mediante un vector de métricas. Su virtud es dar un lenguaje universal para hablar de riesgo entre equipos; su trampa es que casi todo el mundo usa solo la métrica **base** —la severidad intrínseca del fallo— e ignora las otras dos. La **temporal** ajusta según exista o no un exploit público y madurez del mismo. La **ambiental** —la más olvidada y la más importante— ajusta según *tu* contexto: una vulnerabilidad crítica en un servidor de pruebas aislado sin datos puede importar menos que una media en el servidor de facturación expuesto. Reportar solo el CVSS base es entregar una lista ordenada por una severidad teórica que no coincide con el riesgo real del cliente.

La conclusión práctica enlaza con el resto de la parte. El escáner produce un punto de partida, no un veredicto: hay que **verificar manualmente** los hallazgos relevantes (cruzando CVE, CPE y buscando si existe un exploit público real), **descartar los falsos positivos** y **priorizar por impacto de negocio**, no por número. Un informe de cientos de "críticas" sin depurar pierde toda credibilidad ante el equipo de TI que tiene que arreglarlas y, peor, entierra las tres que de verdad importan bajo el ruido de las otras doscientas.

Cómo lo nombra el catálogo CWE y qué cambia al priorizar

Un informe de escáner mezcla datos de procedencias distintas, y conviene saber cuáles son para no darles más crédito del que merecen. El **identificador** (CVE) nombra una vulnerabilidad concreta y lo asigna la autoridad de numeración del producto; la **puntuación** (CVSS) la calcula quien escribió el plugin o la copia de una base pública; y el **CWE**, la causa común, rara vez lo muestra el escáner, de modo que si lo necesitas se obtiene del registro del CVE. Esto importa porque las fuentes pueden discrepar: en los casos reales del programa, el mismo CVE tiene 9,8 según NVD y 7,5 según CISA-ADP (CVE-2021-41773) y 9,8 según NVD frente a 6,3 según su CNA (CVE-2024-2021). Un informe responsable declara de dónde sale cada cifra.

Y no des por hecho que el dato de NVD estará disponible. En una muestra de 4.822 CVE publicados entre el 1 y el 10 de septiembre de 2026 (consulta del 2026-10-30), NVD había publicado una puntuación CVSS 3.1 propia para 399 (8,3 %), mientras que 4.285 (88,9 %) tenían CVSS 3.1 de **alguna** fuente, incluido el CNA. Un escáner que dependa únicamente de NVD ve una fracción de lo que existe. Además, CVSS v4.0 ya está en 1.355 de esos registros, por lo que conviene etiquetar la versión y el grupo de métricas (CVSS-B, BT, BE, BTE; ver clase 368). La prioridad, por último, no sale del CVSS: se completa con KEV, EPSS y la exposición del activo, tal como se explica en la clase 369.

📖 Definiciones y características

- **Nessus (Tenable)**: escáner de vulnerabilidades comercial con motor de plugins (NASL - Nessus Attack Scripting Language). Característica clave: base de firmas actualizada diariamente y detección de configuraciones erróneas además de CVEs.
- **OpenVAS / GVM (Greenbone Vulnerability Management)**: suite open source que sucede al proyecto original OpenVAS; usa NVTs (Network Vulnerability Tests) en lugar de plugins propietarios. Característica clave: feed comunitario (Greenbone Community Feed) actualizado a diario, totalmente auditable.
- **CVSS (Common Vulnerability Scoring System)**: estándar del FIRST (Forum of Incident Response and Security Teams) para puntuar severidad de 0.0 a 10.0. Característica clave: se compone de métricas base (inmutables), temporales (cambian con el tiempo, ej. disponibilidad de exploit) y ambientales (ajustadas al contexto del activo).
- **CVE (Common Vulnerabilities and Exposures)**: identificador único y estandarizado (ej. CVE-2024-XXXX) mantenido por MITRE para una vulnerabilidad específica. Característica clave: es un identificador, no una puntuación de severidad.
- **NVD (National Vulnerability Database)**: base de datos del NIST que enriquece cada CVE con puntaje CVSS, CWE y referencias. Característica clave: es la fuente "oficial" que los escáneres consultan para enriquecer sus plugins.
- **EPSS (Exploit Prediction Scoring System)**: puntaje de FIRST que estima la probabilidad de que un CVE sea explotado en los próximos 30 días. Característica clave: complementa a CVSS porque mide probabilidad real de explotación, no solo severidad técnica.
- **Falso positivo**: hallazgo reportado por el escáner que no representa un riesgo real (banner mal interpretado, versión backportada con parche aplicado). Característica clave: requiere verificación manual (banner grabbing, prueba de concepto) antes de reportarlo al cliente.
- **Política de escaneo (scan policy)**: conjunto de parámetros (puertos, plugins habilitados, credenciales, agresividad) que define cómo se comporta el escáner. Característica clave: debe alinearse siempre con las reglas de engagement (RoE) firmadas.

📓 Glosario

Término	Definición concisa
Escáner de vulnerabilidades	Herramienta que compara el objetivo con firmas conocidas
Nessus	Escáner comercial estándar de la industria
OpenVAS / Greenbone (GVM)	Alternativa open source
Plugin / NVT	Comprobación individual de un escáner
Base de firmas	Catálogo de problemas conocidos que el escáner busca
Escaneo autenticado	Con credenciales; audita desde dentro, menos falsos positivos
Escaneo no autenticado	Sin credenciales; vista de atacante externo
Plantilla de política	Perfil de escaneo que acota intensidad y riesgo
Falso positivo	Hallazgo reportado que no se sostiene al verificarlo
CVSS	Puntuación de severidad de 0 a 10
Métrica base	Severidad intrínseca del fallo
Métrica temporal	Ajuste por existencia y madurez de exploit
Métrica ambiental	Ajuste por el contexto del activo; la más olvidada
Verificación manual	Confirmar un hallazgo cruzando CVE, CPE y exploits
Priorización	Ordenar por impacto de negocio, no por número

🧰 Herramientas y preparación

- **Máquina atacante**: Kali Linux o Parrot OS (VM), 4 GB RAM mínimo, red interna tipo "host-only" o "internal network" en VirtualBox/VMware — **nunca** conectada directamente a redes de producción o internet sin control.
- **Nessus Essentials**: descargar desde `tenable.com/products/nessus/nessus-essentials`, registrar activation code gratuito (email), instalar `.deb` / `.rpm` según distro:

`bash sudo dpkg -i Nessus-*.deb sudo systemctl start nessusd # Interfaz web en https://localhost:8834`

- **OpenVAS/GVM**: en Kali puede instalarse nativo o vía Docker. Nativo:

`bash sudo apt update && sudo apt install -y openvas sudo gvm-setup sudo gvm-start # Interfaz web en https://localhost:9392`

Vía Docker: `docker pull greenbone/gvm` seguido de un `docker-compose` con los servicios `gvmd`, `ospd-openvas`, `redis-server` y `notus-scanner`. - **Máquinas víctima**: Metasploitable2 y Metasploitable3 (VMs deliberadamente vulnerables de Rapid7), desplegadas en la misma red interna aislada. - **Complementos**: `nmap` para descubrimiento previo, navegador para las consolas web de Nessus/GVM, cuenta de NVD (`nvd.nist.gov`) para consulta manual de CVEs.

> ⚠️ **Nota ética:** las técnicas de esta clase (escaneo de vulnerabilidades a escala, algunos plugins intrusivos que pueden reiniciar servicios) se practican **exclusivamente** en laboratorios propios (VMs propias, Metasploitable, rangos tipo HackTheBox/TryHackMe) o contra sistemas con autorización explícita por escrito (contrato de pentesting con reglas de engagement firmadas). El acceso o escaneo no autorizado de sistemas de terceros es ilegal en la gran mayoría de jurisdicciones, incluso sin llegar a explotar nada.

🧪 Laboratorio guiado

> Todo el laboratorio se ejecuta en una red interna aislada (host-only), contra Metasploitable2/3 desplegadas por el propio alumno.

1. Levantar la red interna en el hipervisor y confirmar que Kali y Metasploitable2 están en el mismo segmento sin salida a producción: `ip a` en Kali, `ping <IP-metasploitable>`.
2. Iniciar el servicio de Nessus (`sudo systemctl start nessusd`) y acceder a `https://localhost:8834`, completando el asistente con el activation code.
3. Crear un nuevo escaneo: **New Scan** → **Basic Network Scan**, definir `Name: Lab-Metasploitable2`, `Targets: 192.168.56.101` (IP de la víctima).
4. Configurar credenciales SSH en la pestaña **Credentials** para habilitar escaneo autenticado (usuario `msfadmin`, contraseña `msfadmin` — credenciales por defecto documentadas de Metasploitable2).
5. Lanzar el escaneo y esperar finalización; revisar el resumen por severidad (Critical/High/Medium/Low/Info).
6. Abrir un hallazgo "Critical", leer el **Synopsis**, **Description**, **Solution** y el vector CVSS asociado (ej. `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`).
7. Levantar GVM (`sudo gvm-start` o `docker-compose up -d` según la instalación) y esperar sincronización del feed comunitario (puede tardar horas la primera vez).
8. Acceder a `https://localhost:9392` (usuario `admin` generado en el setup), crear una **Target** apuntando a la misma IP de Metasploitable2.
9. Crear una **Task** con el template **Full and fast**, asociarla al target y ejecutarla.
10. Comparar los resultados de Nessus y GVM para el mismo host: identificar coincidencias y discrepancias en severidad.
11. Tomar un CVE reportado por ambos escáneres y buscarlo manualmente en `nvd.nist.gov` para confirmar el puntaje CVSS base y consultar su EPSS.
12. Clasificar al menos tres hallazgos como verdadero positivo, falso positivo o "requiere verificación adicional", documentando el criterio usado.

✍️ Ejercicios

1. Instalar Nessus Essentials y realizar un escaneo de descubrimiento (host discovery) sobre el rango `192.168.56.0/24`.
2. Configurar un escaneo autenticado completo contra Metasploitable2 y exportar el reporte en formato PDF/HTML.
3. Instalar GVM y ejecutar una tarea "Full and fast" contra la misma víctima, comparando tiempos de ejecución con Nessus.

4. Tomar los cinco hallazgos "Critical" de Nessus, buscar su CVE en NVD y documentar el vector CVSS y el EPSS de cada uno.
5. Identificar al menos un falso positivo en los resultados y justificar por escrito por qué no representa riesgo real.
6. Redactar una tabla de priorización de remediación (Critical → Info) considerando explotabilidad (EPSS), exposición e impacto de negocio simulado.

📝 Reto verificable

Reto: Ejecutar escaneos autenticados con Nessus y GVM contra Metasploitable2 y producir un informe consolidado que incluya: (a) total de hallazgos por severidad de cada herramienta, (b) al menos 5 CVEs verificados manualmente en NVD con su vector CVSS y EPSS, y (c) una tabla de priorización con al menos 3 hallazgos marcados como falso positivo con justificación.

Criterio de aceptación: El informe debe listar como mínimo un hallazgo "Critical" (ej. vsftpd 2.3.4 backdoor, CVE-2011-2523) detectado por ambas herramientas, con su vector CVSS transcrito correctamente y una recomendación de remediación coherente con la solución sugerida por el escáner.

⚠️ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Nessus queda en "Activating..." indefinidamente	Falta conexión a internet para validar el activation code la primera vez; verificar DNS/proxy y reintentar
GVM: "No suitable feed found" o tarea nunca inicia	El feed comunitario aún no terminó de sincronizar; esperar con `sudo greenbone-feed-sync` y revisar logs de `notus-scanner`
Escaneo autenticado marcado como "Credentialed checks: no"	Credenciales SSH incorrectas o servicio SSH deshabilitado en el target; validar con `ssh msfadmin@<IP>` manualmente
El escáner tumba un servicio de la víctima	Política demasiado agresiva (plugins de DoS habilitados); usar plantilla "Basic Network Scan" sin plugins destructivos en labs frágiles
Reporte lleno de "Info" sin hallazgos accionables	Escaneo no autenticado contra un host bien parchado externamente; complementar con escaneo autenticado y revisión manual de servicios
Discrepancia grande entre Nessus y GVM para el mismo host	Feeds de plugins/NVTs distintos y con distinta fecha de actualización; documentar la discrepancia en vez de descartarla sin análisis

❓ Preguntas frecuentes

❓ **¿Es legal usar Nessus u OpenVAS contra cualquier IP que yo elija?** No. Solo es legal contra sistemas propios o con autorización explícita por escrito (contrato de pentesting con reglas de engagement). Escanear activos de terceros sin permiso puede constituir un delito informático incluso sin explotación posterior.

❓ **¿Un escáner de vulnerabilidades reemplaza el pentest completo?** No. El escáner detecta vulnerabilidades conocidas por firma, pero no encadena ataques, no valida impacto real ni encuentra fallos de lógica de negocio. Es una herramienta dentro del proceso de pentest, no un sustituto.

❓ **¿Un puntaje CVSS alto significa que debo remediar primero esa vulnerabilidad?** No necesariamente. CVSS base no considera si el activo es crítico para el negocio ni si el exploit está siendo usado activamente; para eso existen el vector temporal, el ambiental, EPSS y fuentes como CISA KEV.

❓ **¿Nessus Essentials sirve para un pentest profesional real?** Essentials está limitado a 16 IPs y licenciamiento personal/educativo; para engagements comerciales se usa Nessus Professional o Tenable.io bajo licencia adecuada.

🔗 Referencias

- 🏢 **En la empresa:** los escáneres comerciales equivalentes son **Tenable Nessus / Tenable.io**, **Qualys VMDR** y **Rapid7 InsightVM (Nexpose)** — mismos conceptos, distinta herramienta según el empleador.
- Rapid7, documentación oficial de Metasploitable2/3: https://github.com/rapid7/metasploitable3
- Tenable, Nessus Essentials: https://www.tenable.com/products/nessus/nessus-essentials
- Greenbone Networks, documentación de GVM: https://greenbone.github.io/docs/
- FIRST, CVSS v3.1 Specification Document y EPSS: https://www.first.org/cvss/v3.1/specification-document · https://www.first.org/epss/
- NIST National Vulnerability Database: https://nvd.nist.gov
- PTES (Penetration Testing Execution Standard), fase Vulnerability Analysis: http://www.pentest-standard.org

📥 Material descargable

- 📄 Guía en PDF — versión imprimible de esta clase.
- 🎞️ Presentación (PPTX) — deck para proyectar en clase.

⬅️ Clase anterior

Clase 070 — Enumeración: SMB, SNMP, SMTP y LDAP

➡️ Siguiente clase

Clase 072 — Metasploit Framework: arquitectura y uso